



מתודולוגיית MITRE ATT&CK: המדריך השלם להבנת התוקף

ממיפוי הכאוס למודיעין אופרטיבי – הדרך להגנת
סייבר מבוססת איומים

ד"ר מיכאל טיבין

Alert Red

מצגת סקירה מקצועית לאנשי אבטחת מידע ו-SOC

ATT&CK®

Random Page ▼

ATT&CK Matrix for Enterprise

hide sub-techniques

המכללה
האקדמית
רמת גן

TECHNIQUES

- Boot or Logon Autostart Execution ▾
- Boot or Logon Initialization Scripts ▾
- Cloud Application Integration
- Compromise Host Software Binary
- Create Account ▾
- Create or Modify System Process ▾
- Event Triggered Execution ▾
- Exclusive Control
- External Remote Services
- Hijack Execution Flow ▾
- Implant Internal Image
- Modify Authentication Process ▾
- Modify Registry
- Office Application Startup ▾
- Power Settings
- Pre-OS Boot ▾
- Scheduled Task/Job ▾
- Server Software Component ▾
- Software Extensions ▾
- Traffic Signaling ▾
- Valid Accounts ▾
- Privilege Escalation ▾
- Defense Evasion ▾
- Credential Access ▾
- Discovery ▾
- Lateral Movement ▾
- Collection ▾
- המכללה
האקדמית
רמת גן

Home > Techniques > Enterprise > Cloud Application Integration

Cloud Application Integration

Adversaries may achieve persistence by leveraging OAuth application integrations in a software-as-a-service environment. Adversaries may create a custom application, add a legitimate application into the environment, or even co-opt an existing integration to achieve malicious ends.^{[1][2]}

OAuth is an open standard that allows users to authorize applications to access their information on their behalf. In a SaaS environment such as Microsoft 365 or Google Workspace, users may integrate applications to improve their workflow and achieve tasks.

Leveraging application integrations may allow adversaries to persist in an environment – for example, by granting consent to an application from a high-privileged adversary-controlled account in order to maintain access to its data, even in the event of losing access to the account.^{[3][4][5]} In some cases, integrations may remain valid even after the original consenting user account is disabled.^[6] Application integrations may also allow adversaries to bypass multi-factor authentication requirements through the use of [Application Access Tokens](#). Finally, they may enable persistent [Automated Exfiltration](#) over time.^[7]

Creating or adding a new application may require the adversary to create a dedicated [Cloud Account](#) for the application and assign it [Additional Cloud Roles](#) – for example, in Microsoft 365 environments, an application can only access resources via an associated service principal.^[8]

Procedure Examples

ID	Name	Description
C0059	Salesforce Data Exfiltration	During Salesforce Data Exfiltration , threat actors deceived victims into authorizing malicious connected apps to their organization's Salesforce portal. ^{[9][10]}

Mitigations

ID	Mitigation	Description
M1047	Audit	Periodically review SaaS integrations for unapproved or potentially malicious applications.
M1042	Disable or Remove Feature or Program	Do not allow users to add new application integrations into a SaaS environment. In Entra ID environments, consider enforcing the "Do not allow user consent" option. ^[11]

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0539	Detection Strategy for Cloud Application Integration	AN1487	Detects suspicious OAuth application integrations within Office 365 or Google Workspace environments, such as new app registrations, unexpected consent grants, or privilege assignments. Defenders should correlate between application creation/modification events and associated user or service principal activity to identify persistence via app integrations.
		AN1488	Detects anomalous SaaS application integration activity across environments such as Slack, Salesforce, or other enterprise SaaS services. Focus is on unauthorized app additions, unusual permission grants, and persistence through service principal tokens.

ID: T1671

Sub-techniques: No sub-techniques

① **Tactic:** [Persistence](#)

① **Platforms:** Office Suite, SaaS

Version: 1.0

Created: 20 March 2025

Last Modified: 15 April 2025

[Version](#) [Permalink](#)

הדילמה הביטחונית: אסימטריה

הגנה מסורתית

- התמקדות בתיקון חולשות (Patching).
- הנחת יסוד שגויה: "התוקף צריך להצליח רק פעם אחת, המגן צריך להצליח תמיד."

הגנה מבוססת מודיעין

- התמקדות באיומים (Threats).
- היתרון החדש: כדי להצליח, התוקף חייב להשלים את כל השלבים.
- המגן צריך לשבור רק חוליה אחת בשרשרת כדי לסכל את המתקפה.

	December	March	June
Reconnaissance			
Weaponization	◇	→	◇
Delivery	◆	→	◆
Exploitation	→	◆	→
Installation	◆	→	◆
C2	◆	→	◆
Actions on Objectives			

Legend ◇ Detection ◆ Mitigation → Leverage new indicators

הטבלה המחזורית של איומי הסייבר (TTPs)

Tactics (הטקטיקות - ה'למה')

מייצגות את המטרה הטקטית של התוקף (למשל: 'אני צריך להיכנס לרשת' או 'אני צריך לגנוב סיסמאות').

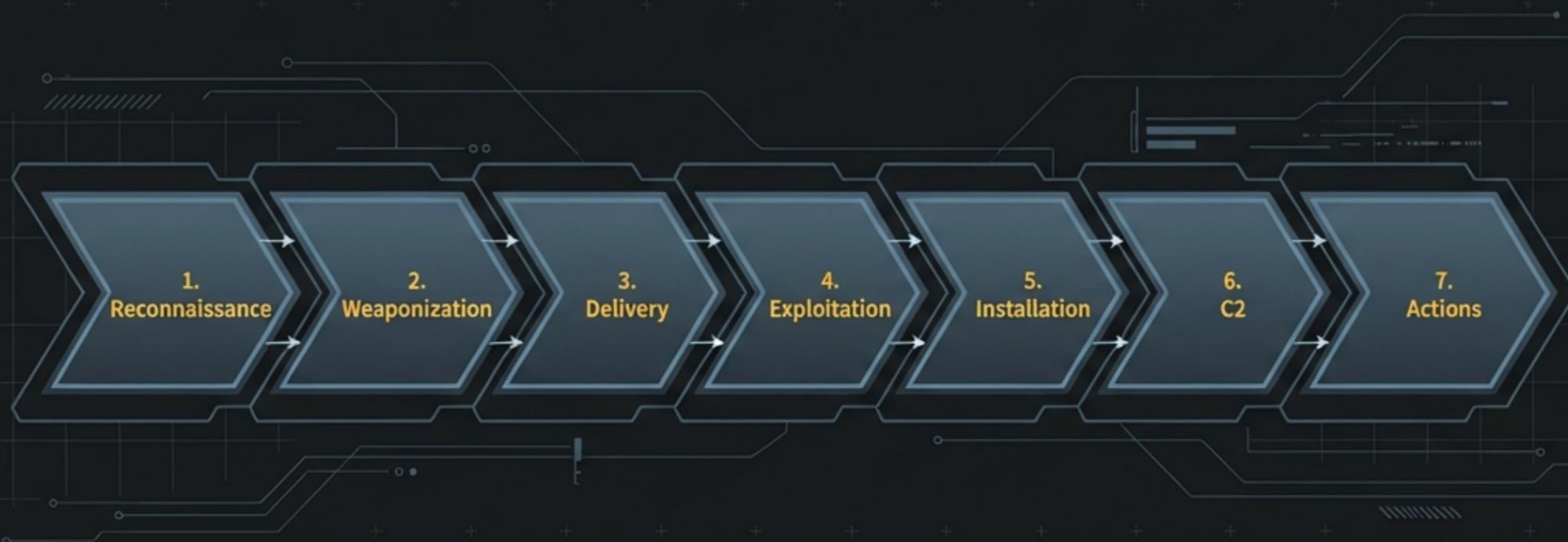
Techniques (הטכניקות - ה'איך')

השיטה הספציפית בה התוקף משתמש כדי להשיג את המטרה (למשל: Phishing כדי להשיג גישה).

Procedures (הנהלים - ה'ביצוע')

הפרטים הטכניים של היישום בפועל. באיזה כלי ספציפי או קוד השתמש התוקף (למשל: שימוש בכלי Mimikatz או Cobalt Strike).

המעבר להגנה מוכוונת מודיעין



Key Terminology

APT: תוקף בעל משאבים, סבלנות ויעדים מוגדרים.

Indicator Life Cycle: המעבר מנתונים גולמיים למודיעין מבצעי.

Definition

מודל שפותח על ידי **Lockheed Martin** לזיהוי ולמידה של דפוסי פעולה של תוקפי **APT** (איומים מתקדמים ומתמשכים).

The Goal

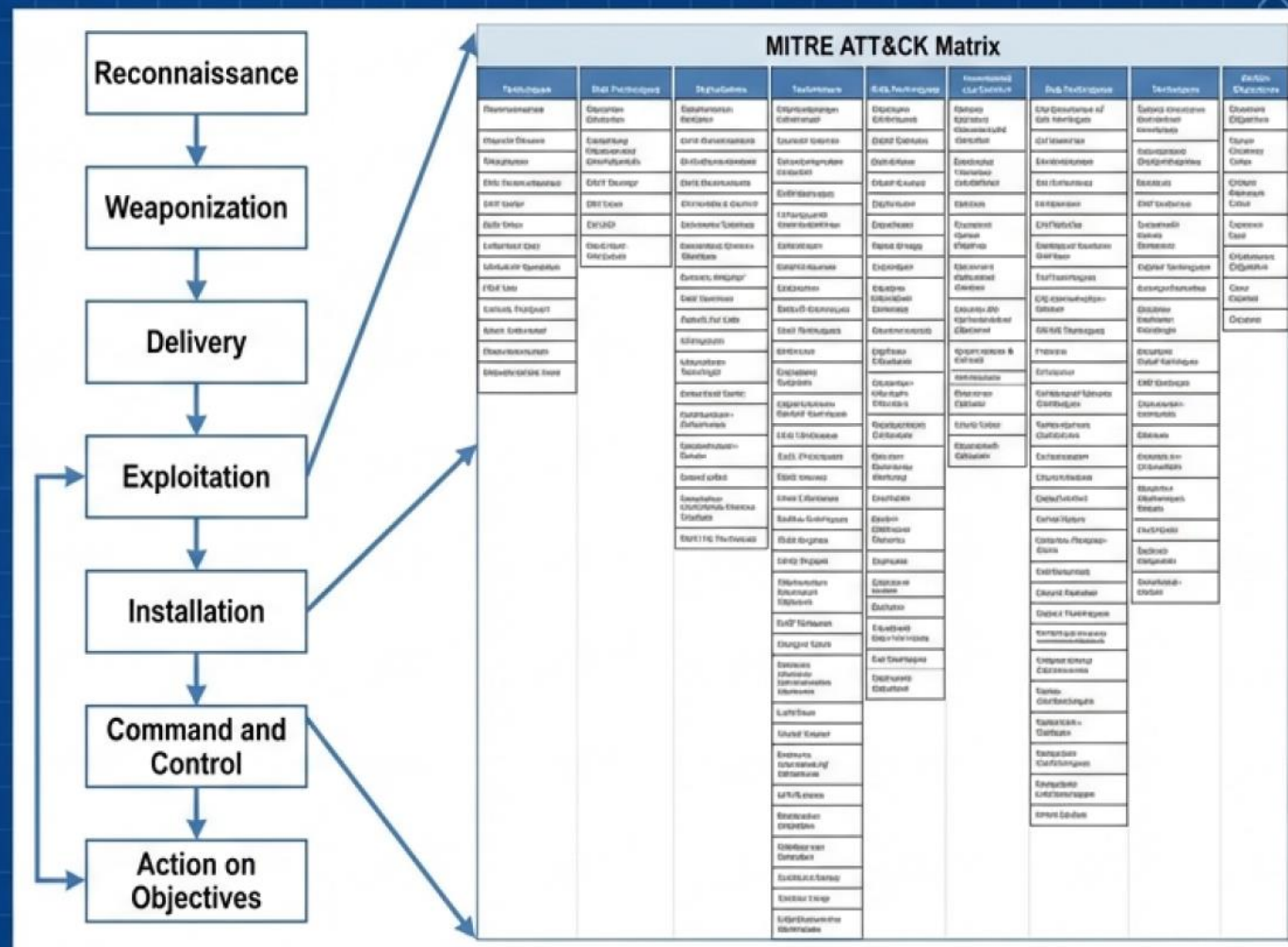
המטרה אינה רק 'לנקות' את המערכת, אלא לייצר מודיעין (**Intelligence Feedback Loop**) שימנע את המתקפה הבאה.

בין Cyber Kill Chain ל-MITRE ATT&K

מודל משלים: ה-Kill Chain (של לוקהיד מרטין) מתאר את *שלבי* התקיפה באופן ליניארי (7 שלבים).
MITRE ATT&CK מפרט את *הכלים* והשיטות *האפשריים בכל שלב*.

ההבדל בגישה: בעוד שה-Kill Chain מתמקד בתהליך נוקשה, ATT&CK בין שלבים ומספק 'מטריצה' של אפשרויות.

עומק טכני: המטריצה של Enterprise Windows, למשל, כוללת 12 **טקטיקות** מרכזיות המכסות את כל מחזור החיים של התקיפה.



שלב 1: החדירה (Getting In)



Reconnaissance (איסוף מודיעין)

איסוף אקטיבי (Nmap) ופסיבי (OSINT, רשתות חברתיות) לאיתור חולשות לפני התקיפה.



Resource Development (פיתוח משאבים)

רכישת דומיינים, הקמת שרתי תקיפה (VPS), ופיתוח או רכישת נוזקות (Malware).



Initial Access (גישה ראשונית)

- הדלת פנימה. טכניקות נפוצות:
- דיוג ממוקד: Phishing: (Spearphishing) דרך מייל.
 - Exploiting Public-Facing Apps: ניצול חולשות בשרתים החשופים לאינטרנט.
 - Supply Chain Compromise: חדירה דרך ספק צד ג'.



שלב 2: התבססות והישרדות (Staying In)

2. Persistence (התמדה/אחיזה)

הבטחת הישרדות הנוזקה גם לאחר אתחול המחשב (למשל: Registry Run Keys, Scheduled Tasks, משתמשים).
יצירת משתמשים.



1. Execution (הפעלה)

הרצת קוד זדוני (למשל באמצעות PowerShell, WMI או משימות מתוזמנות).



4. Defense Evasion (חמקנות)

התחמקות מזיהוי אנטי-וירוס ו-EDR (למשל: מחיקת לוגים, Obfuscation, שימוש בתוכנות בתוכנות לגיטימיות למטרות זדוניות - 'Living off the Land').



3. Privilege Escalation (העלאת הרשאות)

המעבר ממשתמש רגיל ל-Admin/System. ניצול חולשות ב-Kernel או בקרת גישה לקויה.



שלב 3: התפשטות ברשת (Moving Around)



שלב 4: ביצוע המשימה (The Endgame)



Collection (איסוף)

ריכוז המידע הרגיש
(צילומי מסך, גניבת
גניבת קבצים, הקלטת
אודיו/וידאו).



Command & Control (C2)

התקשורת החוצה לשרת
התוקף לקבלת פקודות.
שימוש בערוצים מוצפנים
או פרוטוקולים לגיטימיים
מסוודונים לגיטימיים
(HTTPS/DNS) להסוואה.



Exfiltration (הוצאת מידע)

גניבת המידע החוצה,
לעיתים קרובות תוך
שימוש בהצפנה ודחיסה
כדי להימנע מזיהוי DLP.



Impact (השפעה/נזק)

שיבוש הפעילות העסקית.
דוגמאות: הצפנת דיסק
(Ransomware),
מחיקת מידע
(Data Destruction), או
השחתת אתרים
(Defacement).

שלב 5: התקנה (Installation)

תוקר



המטרה: ביסוס נוכחות קבועה (Persistence) במערכת.

טכניקות:

- התקנת דלת אחורית (Backdoor/RAT).
- שינוי רג'יסטרי להפעלה אוטומטית (AutoRun).
- Privilege Escalation (העלאת הרשאות למנהל מערכת).

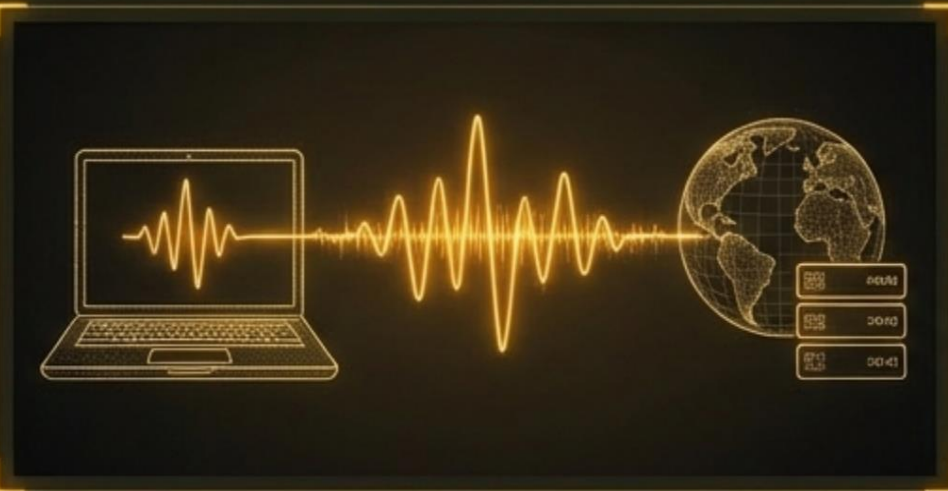
מגן



- **זיהוי:** HIDS (מערכות זיהוי חדירה למארח).
- **בידוד:** שימוש ב-'Chroot jails' להגבלת יכולת התנועה של התהליך הזדוני.
- **ניטור:** מעקב אחר שינויי קבצים (File Integrity Monitoring).

שלב 6: פיקוד ושליטה (Command & Control - C2)

תוקף (Attacker)



המטרה: יצירת ערוץ תקשורת דו-כיווני ('Hands on Keyboard').

טכניקות:

- Beaconing (שידור אותות חיים לשרת התוקף).
- הסתרת תעבורה בתוך פרוטוקולים לגיטימיים (DNS Tunneling, HTTP, SSL).

מגן (Defender)



• **חשיבות:** זהו 'חבל ההצלה' של התוקף. ניתוקו מנטרל את המתקפה.

• **תגובה:** DNS Sinkholing (הפניית התוקף לשרת דמי), חסימות ב-Firewall, ניתוח תבניות תעבורה חריגות.

שלב 7: ביצוע פעולות ביעד (Actions on Objectives)

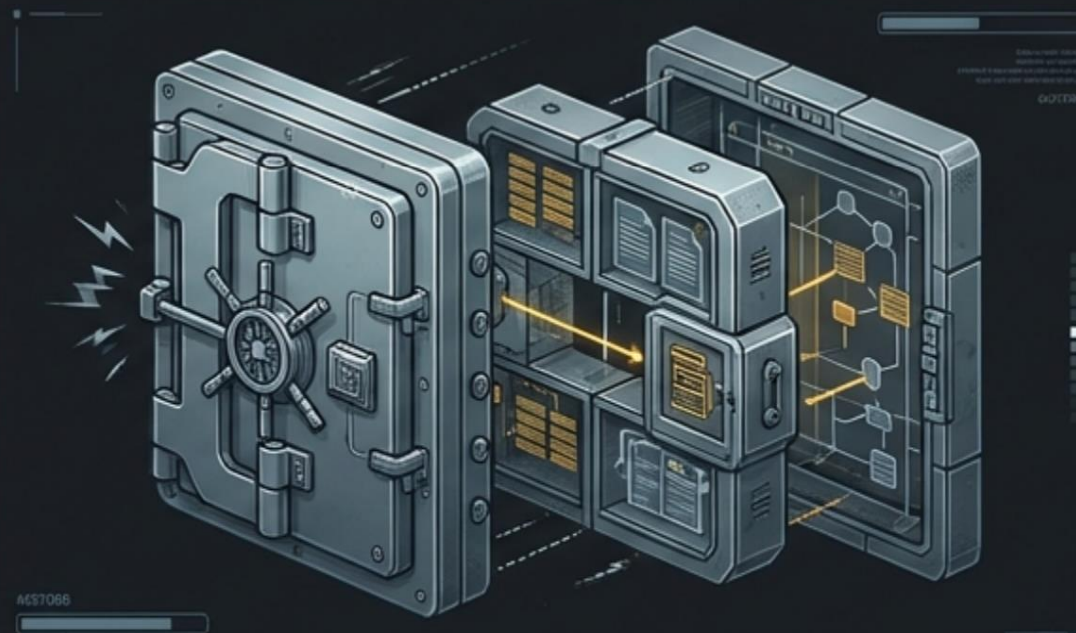
תוקף



המטרה: השגת היעד האסטרטגי של המתקפה.
פעולות:

- **Exfiltration:** גניבת מידע רגיש.
- **Encryption:** הצפנת מידע לצורכי סחיטה (Ransomware).
- **Lateral Movement:** תנועה רוחבית בתוך הרשת למערכות קריטיות נוספות.

מגן



תגובה:

DLP (מניעת דלף מידע), סגמנטציה של הרשת
(Network Segmentation), תגובה מהירה לאירוע
(Rapid Incident Response)

מטריצת הפעולה: הגנה רב-שכבתית

	Detect (זיהוי)	Deny (מניעה)	Disrupt (שיבוש)	Degrade (דיכוי)	Deceive (הטעיה)	Destroy (השמדה)
Reconnaissance (סיור)	✓					
Weaponization (התחמשות)						
Delivery (משלוח)	✓					
Exploitation (ניצול)		👤 × 🛡️				
Installation (התקנה)	✓					
C2 (פיקוד ושליטה)			👤 × 💣		🛡️ × 🐝	
Actions (פעולות ביעד)	✓	👤 × 🛡️				



Detect (זיהוי)
ניתוח וזיהוי
ניסיונות חדירה.

SIGNAL AMBUSH



Deny (מניעה)
עצירת ההתקפה
בזמן אמת.

DEFENSE SLATS



Disrupt (שיבוש)
פגיעה בתקשורת
הנתונים של התוקף.

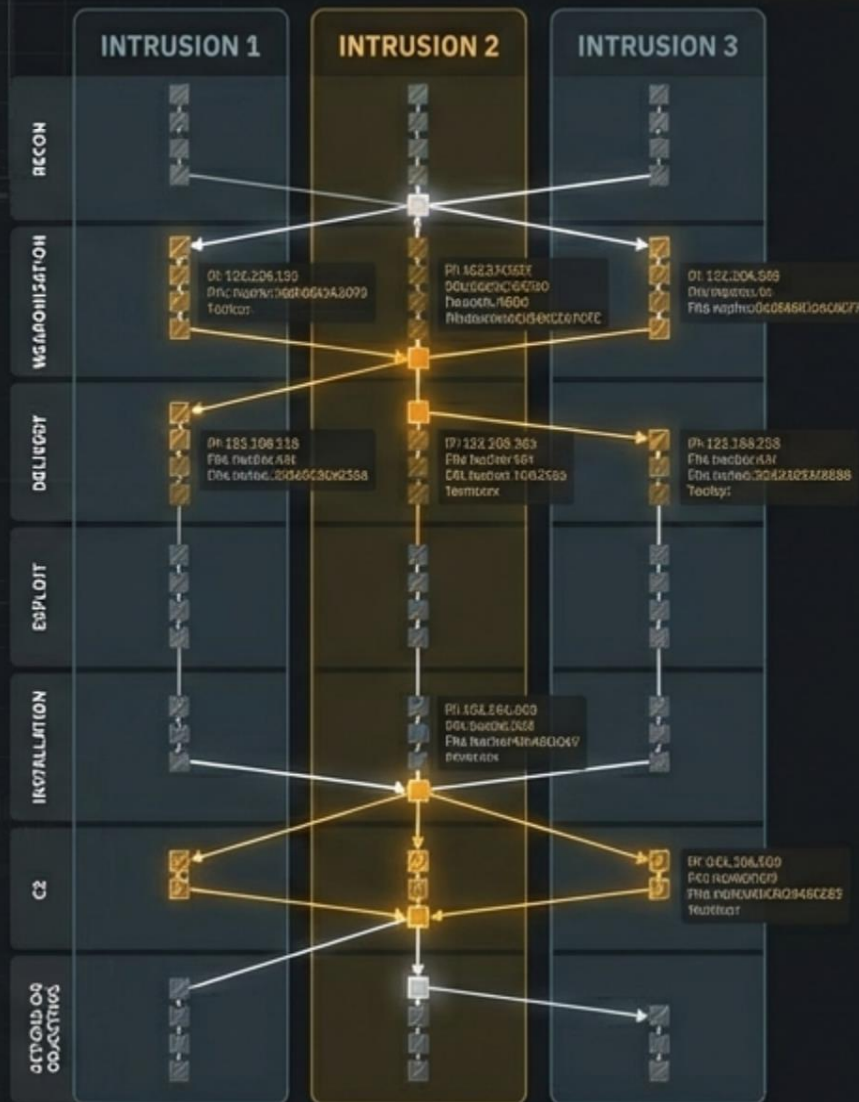
DEFENSE SLATE



Deceive (הטעיה)
הובלת התוקף
למלכודות דבש
(Honeypots).

DEFENSE MATE

המטרה היא לייצר עומק הגנתי (Defense in Depth).



- **העיקרון:** אסור לנתח אירוע בודד במנותק. יש לחפש דפוסים חוזרים.
- **היתרון המודיעיני:** ההתמדה של התוקף הופכת לנקודת התורפה שלו.
- שימוש חוזר בתשתיות, כלי נשק או טכניקות (TTPs) מאפשר למגן לזהות את ה'קמפיין' ולחזות את הצעד הבא.

מסקנה:

זיהוי מכנה משותף אחד (למשל, כתובת IP של שרת C2) יכול לשרוף קמפיין שלם של התוקף.

אתגרים ומגבלות במודל המסורתי

Cloud / IoT Bypass

Perimeter Defense

Insider Threat

התמקדות בהיקף (Perimeter Focus):

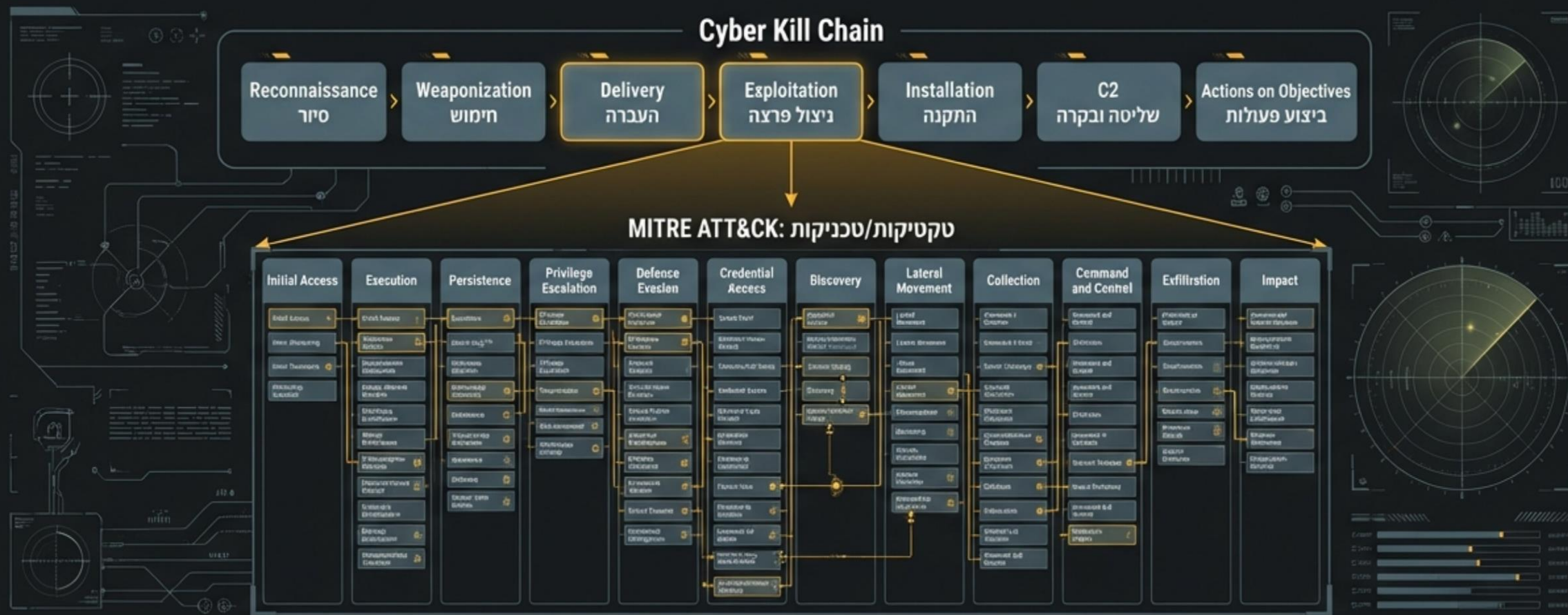
המודל המקורי מניח שהתוקף מגיע מבחוץ.
פחות יעיל כנגד איומים פנימיים
(Insider Threats).

שינוי הנוף הטכנולוגי: המעבר לענן (Cloud)
ול-IoT משנה את גבולות הגזרה.

דילוג על שלבים: תוקפים מודרניים עשויים
לדלג על שלבים (למשל, באמצעות רכישת
גישה קיימת).

הסתגלות התוקף: עצם הכרת המודל מאפשרת
לתוקפים לשנות טקטיקה כדי להימנע גילוי.

השילוב המנצח: CKC & MITRE ATT&CK

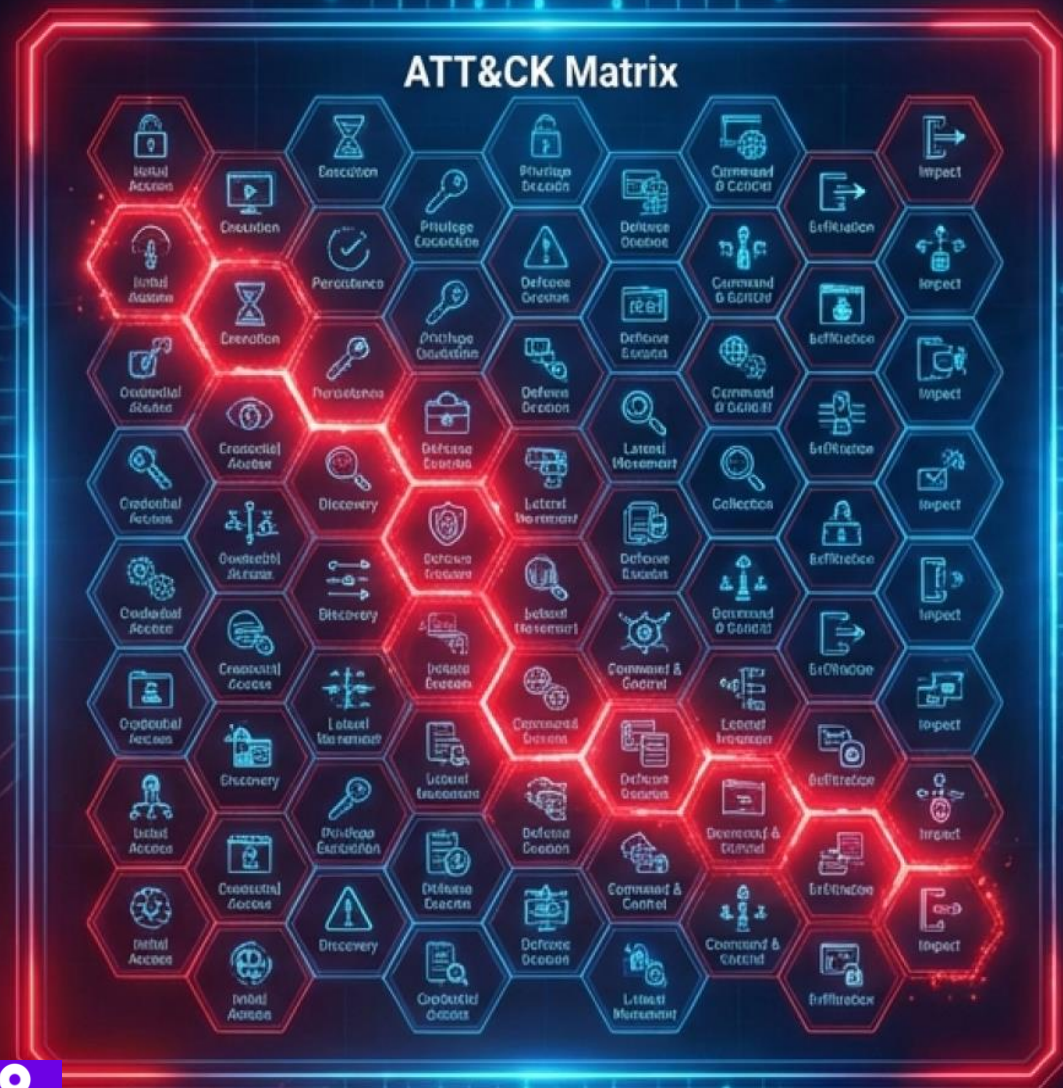


Cyber Kill Chain: מספקת את ההקשר האסטרטגי ("באיזה שלב של התקיפה אנחנו נמצאים?"). מצוינת לזיהוי מוקדם ומניעה.

MITRE ATT&CK: מספקת את המידע הטקטי המפורט ("איזו טכניקה ספציפית מופעלת?"). מצוינת מצוינת לציד אימים (Threat Hunting) ולניתוח לאחר חדירה.

הסינרגיה: שימוש ב-CKC כדי לבנות תרחישי Red Team, ושימוש ב-MITRE כדי לוודא כיסוי הגנתי מלא.

יישום 1: מודיעין איומים (Know Your Enemy)



APT19 Profile

פרופיל תוקף: שימוש ב-ATT&CK למיפוי קבוצות תקיפה רלוונטיות למגזר שלכם (למשל, קבוצת APT19 המכוונת למגזרים ספציפיים).

מיקוד ההגנה: אם ידוע שהתוקף משתמש בטכניקה ספציפית (למשל Registry Run Keys), ניתן למקד את ניטור ה-SOC לזיהוי חריגות באזור זה.

שיתוף מידע: סטנדרטיזציה של דוחות מודיעין מאפשרת שיתוף מהיר של IOCs ו-TTPs בין ארגונים.

יישום 2: ניתוח פערים בהגנה (Know Yourself)

מיפוי יכולות: הצלבת כלי ההגנה הקיימים (EDR, SIEM, FW) אל מול המטריצה.

זיהוי שטחים מתים: יצירת 'מפת חום' (Heat Map) – ירוק (מכוסה), צהוב (כיסוי חלקי), אדום (חשוף).

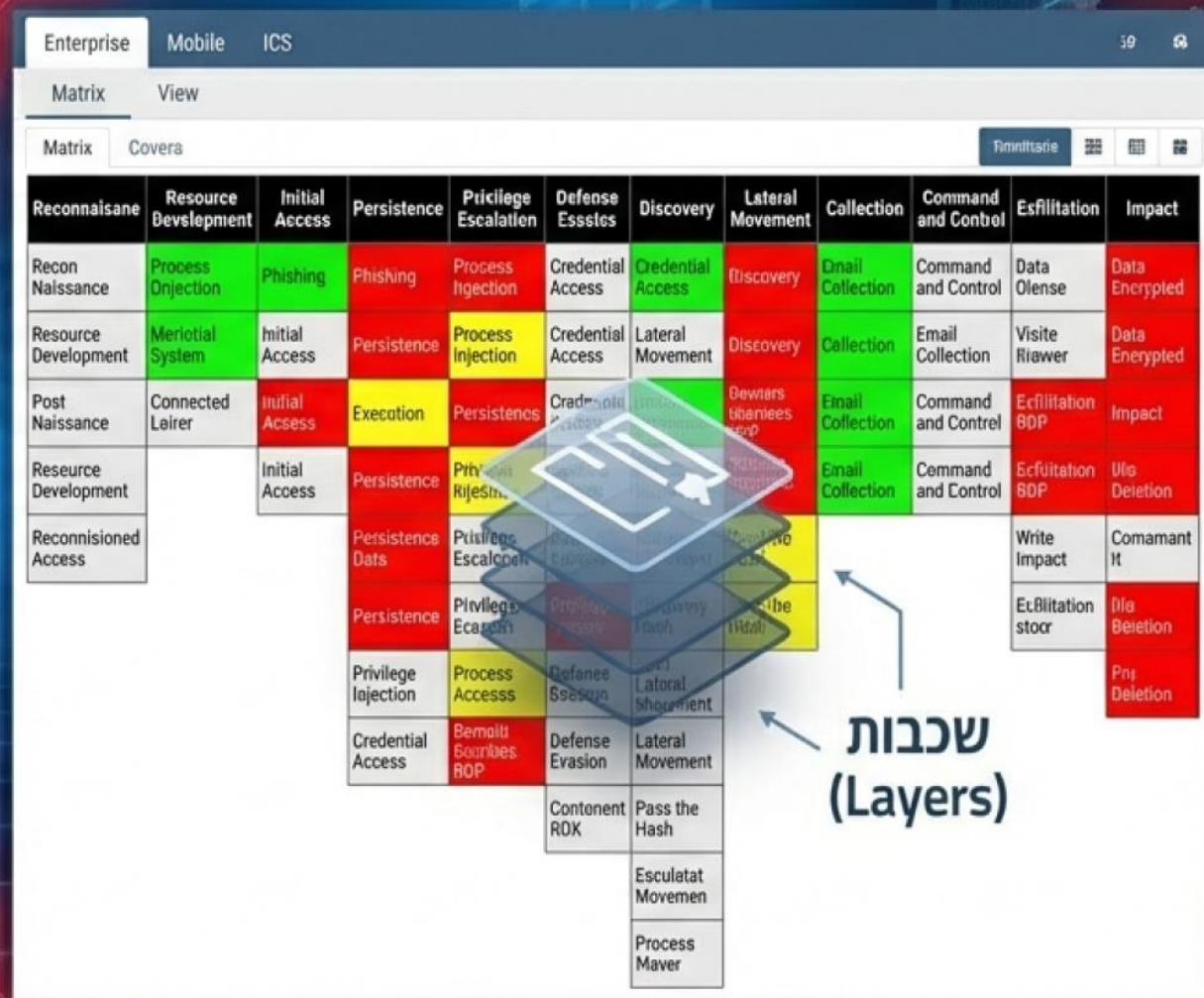
דוגמא: "אנחנו מצוינים בזיהוי Phishing (שלב הגישה), אך עיוורים לחלוטין ל-Lateral Movement באמצעות RDP".

Reconnaissance	Resource Development	Initial Access	Persistence	Privilege Escalation	Defense Evasion	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Reconnaissance	Process Injection	Phishing	Phishing	Process Injection	Credential Access	Credential Access	Discovery	Email Collection	Command and Control	Data Denial	Data Encrypted
Resource Development	Initial System	Initial Access	Persistence	Process Injection	Credential Access	Lateral Movement	Discovery	Collection	Email Collection	Visits Stammer	Data Encrypted
Post Reconnaissance	Connected Lateral	Initial Access	Execution	Persistence	Credential Access	Lateral Movement	Remote Services: RDP	Email Collection	Command and Control	Exfiltration RDP	Impact
Resource Development		Initial Access	Persistence	Process Injection	Defense Access	Plaintiff Hash	Remote Services: RDP	Email Collection	Command and Control	Exfiltration RDP	File Deletion
Reconnaissance	Access		Persistence	Privilege Escalation	Defense Evasion	Lateral Movement	Pass the Hash			Write Impact	Compromised It
			Persistence	Privilege Evasion	Defense Access	Discovery Hash	Pass the Hash			Exfiltration Stammer	File Deletion
			Privilege Injection	Process Injection	Defense Evasion	Start Lateral Movement					File Deletion
			Credential Access	Remote Services: RDP	Defense Evasion	Lateral Movement					
					Contest Disk	Pass the Hash					
						Escalate Discretion					
						Process Player					

(Covered) ■ (Partial) ■ (Vulnerable) ■ כיסוי חלקי

הכלי המרכזי: MITRE ATT&CK Navigator

- כלי קוד פתוח המאפשר ויזואליזציה של המטריצה.
- שימוש בשכבות (Layers):** היכולת להניח שכבות מידע זו על גבי זו. למשל: שכבה המייצגת את תוקף X, מול שכבה המייצגת את יכולות ההגנה של הארגון.
- התאמה אישית:** יצירת מטריצות מותאמות לאיומים ספציפיים (למשל Ransomware) או טכנולוגיות ספציפיות (Cloud vs. On-Prem).



Reconnaissance	Resource Development	Initial Access	Persistence	Privilege Escalation	Defense Evasion	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Reconnaissance	Process Injection	Phishing	Phishing	Process Injection	Credential Access	Credential Access	Discovery	Email Collection	Command and Control	Data Exfiltration	Data Encrypted
Resource Development	Malicious System	Initial Access	Persistence	Process Injection	Credential Access	Lateral Movement	Discovery	Collection	Email Collection	Visits Ransomware	Data Encrypted
Post Reconnaissance	Connected Lateral	Initial Access	Execution	Persistence	Credential Access	Discovery	Discovery	Email Collection	Command and Control	Exfiltration ROP	Impact
Resource Development		Initial Access	Persistence	Privilege Escalation	Defense Evasion	Discovery	Discovery	Email Collection	Command and Control	Exfiltration ROP	Impact
Reconnaissance			Persistence	Privilege Escalation	Defense Evasion	Discovery	Discovery			Write Impact	Command and Control
			Persistence	Privilege Escalation	Defense Evasion	Discovery	Discovery			Exfiltration ROP	Impact
			Privilege Injection	Process Access	Defense Evasion	Lateral Movement	Lateral Movement			Exfiltration ROP	Impact
			Credential Access	Remote Services ROP	Defense Evasion	Lateral Movement	Lateral Movement			Exfiltration ROP	Impact
					Content ROP	Pass the Hash				Exfiltration ROP	Impact
						Escalation Movement				Exfiltration ROP	Impact
						Process Mover				Exfiltration ROP	Impact

מתקדם: סימולציה ואמולציית יריב (Red Teaming)

Red Team
(תוקף)

Red Team
(תוקף)

Blue Team
(מגן)

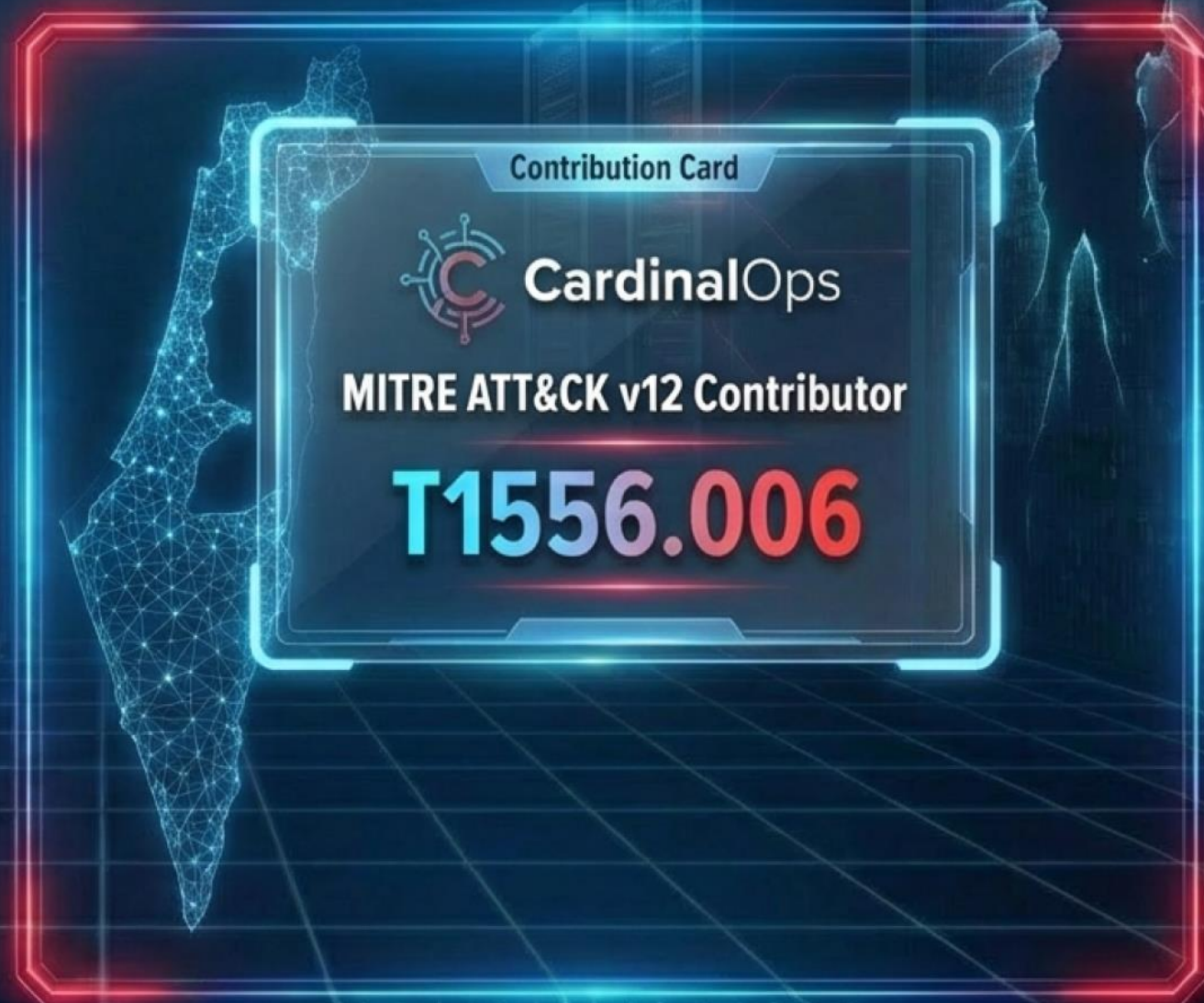
במקום מבדקי חדירה
מבדקי חדירה (Pentest) אקראיים,
שימוש במתווה מדויק של תוקף מוכר
(Adversary Emulation).

בניית תרחיש: יצירת תסריט תקיפה
המבוסס על רצף TTPs אמיתי.

שימוש Atomic Red Team:
בספריות בדיקה פתוחות לבדיקת
לבדיקת בקורות הגנה ספציפיות
(למשל: 'האם המערכת מזהה
הרצת Mimikatz?').

הזווית הישראלית: תרומה למאגר הידע העולמי

- המודל הוא קהילתי ומתעדכן תדיר על ידי חוקרים.
- **תרומה ישראלית (CardinalOps):** צוות המחקר של חברת CardinalOps (יאיר מנור ומיכאל מומצ"וגלו) תרם לגרסה v12 של המודל.
- **הטכניקה החדשה:** זיהוי ותיעוד טכניקה לעקיפת (MFA Bypass) - ממופה כ- T1556.006.
- **המשמעות:** רלוונטיות קריטית ליישום מודל Zero Trust בסביבות Office 365 ו-Azure AD.



סיכום: למה לאמץ את MITRE ATT&CK?

שפה משותפת: סטנדרטיזציה של התקשורת בין צוותי מודיעין, SOC, והנהלה.

הגנה מונחית איומים: מעבר מהגנה 'על הכל' להגנה ממוקדת על הפרצות הסבירות ביותר.

מדידה אובייקטיבית: היכולת לכמת את רמת ההגנה ולזהות פערים בצורה ויזואלית.

קהילה חיה: בסיס ידע שמתעדכן בזמן אמת עם התפתחות איומי הסייבר (כדוגמת התרומה הישראלית).



מקורות וכלים להעמקה



MITRE ATT&CK Official Site

attack.mitre.org -
המאגר המלא.



ATT&CK Navigator

הכלי ליצירת מפות חום
ושכבות הגנה.



Atomic Red Team

ספריית בדיקות לאמולציית
איומים.



See Security

קורסים והכשרות מתקדמות
למקצועות ה-SOC
וה-CISO.

תודה רבה.

